OS_Ticket:

Os Ticket est un system de gestion de tickets de support open source. Il peux integrer les demandes des utilisateurs provenant d'emails de telephones et de formulaires web dans une interface web. Il est écrit en PHP et utilise un backend MySQL Il peux etre installé sur Windows ou Linux

Coté CVE on en a de nombreuses mais l'application est trés mises à jours de sorte qu'il reste rare d'en trouver sur un system en production

Mais avec un peu d'intelligence on peu souvent detourner le fonctionnement de l'application pour parvenir à nos objectifs

Tout au long du processus (surtout pour les tickets urgent et/ou important) on peu etre amener a echanger par mail ou autre avec des membres d'entreprise allié la recuperation d'emails et/ou pseudo pouvant donner lieu à enquete OSINT s'avérent souvent trés interessants.

Il existe de nombreux moyen d'abuser de la logique des tickets du support il est interessant de s'y documenter sur le web (ca a déjà été un vecteur d'attaque d'entreprises du fortune 500!)

Gitlab_Découverte Et Enumération:

GitLab est un outil d'Hebergement de depots basés sur le web qui fournit des fonctionnalités de wiki de suivi de problems de de pipelines d'integration et de deployement continu.

Un pipline (CI/CD) est une suite d'etapes automatisés que doit traverser le code source d'une application pour être validé et deployer.

Ce qui fais de Gitlab une cible de choix pour les hackers car un bon moyen de mener une attaque supplychain

Le numéro de version de Gitlab n'est accessible qu'en étant identifié sur la page /help qu'en avec repositories publics ils sont accessibles sur / explore

Certaines organisation la création de comptes puis l'authentification avec sans verifications préalables, faille a verifié on sais jamais

A Noter que en 2026 la 2FA est activé par défault voir obligatoire sur tout ce types d'application, et ouis la sécurité augmente mais on reste la!

Attaquer Gitlab:

Evidemment les CVE restent un point important à chercher on a même des petites RCE authentifié sur les anciennes versions perso j'en est déjà exploité une sur une version 13 et des patates et mon revshell était super stable pour l'anecdote.

Sinon avec gitlab il est possible d'enumérer les utilisateurs grace à des messages de retour differents en fonction de leurs existence ou non lors de tentatives de logins

A Noter que sur gitlab par défault 10 tentatives échouées resultent en "soft ban" de 10 minutes! elle est longue l'enumeration!

Attaquer le CGI (de Tomcat):

CGI (common gateway interface) est une technologie (ancienne) qui permet à un server web (comme Tomcat notre exemple pour cette section) de communiquer avec des application externes appellés scripts CGI. Les scripts peuvent être écris dans un language comme python perl ou encore pour le cas windos en batch (.bat .cmd)

En gros le server web recoit une requete d'un utilisateur la transmet au script CGI qui l'exécute et renvoie le resultat au server l'utilisateur par le biais du serveur c'est un moyen de generer du contenu dynamique

Les scripts CGI quand il y en a sont souvent dans des repertoires dedié comme /cgi/ ou /WEB-INF/cgi/ pour les trouver on peu essayer de fuzzer par exemple avec ffuf

La CVE-2019-0232 est un cas d'école qui demontre comment sur windows une tel fonctionnalité mal implementé mène a une RCE ...